Report Workshop

User guide

Turn Tenable Security Center or Vulnerability Management data into remediation reports, in your client's colours and in four languages.

November 2026

Local application: Flask, ReportLab, openpyxl. Runs on your computer; data stays on it.

Contents

1. What Report Workshop does 3

How it works, in four steps . . . 3

2. Installation and first launch 3

What you need . . . 3

Updating . . . 4

3. Quick start 4

4. Tour of the interface 5

Profiles and language . . . 5

Theme . . . 5

Generate . . . 5

Branding . . . 6

Scope . . . 7

Configuration . . . 7

5. Getting the data 9

Option A: CSV export from the Security Center interface . . . 9

Option B: query Security Center directly (API) . . . 9

Option C: Tenable Vulnerability Management . . . 9

Choosing the scope . . . 10

Where the fetched data is kept . . . 10

6. The report templates 11

What the pages look like . . . 12

The PHP2Shell template . . . 14

7. Understanding the scores 15

Where the scores appear . . . 15

8. Rules 15

What you can do . . . 16

Fields you can use in a title or an action . . . 17

How the rules are stored . . . 17

9. Sending a report by email 18

10. Command line and automation 18

11. Languages 18

12. What is in the folder 19

Adding a report template . . . 19

13. Troubleshooting 20

1. What Report Workshop does

Report Workshop is a small application that runs on your own computer. It takes vulnerability data from Tenable Security Center or Tenable Vulnerability Management (a CSV export, or a direct query of their API), groups the findings into a short list of concrete actions, and produces a finished report: a PDF for management, a PDF for the teams who will do the work, or an Excel tracking workbook.

Every client can have their own profile (logo, colours, confidentiality mention, watermark, scope, language). The interface and the reports are available in French, English, Spanish and Italian.

How it works, in four steps

1. **Load the data.** Drop a CSV export, or let the application query Security Center or Vulnerability Management through its API. A live log shows each step of an API retrieval.
2. **Group findings into solutions.** A set of rules turns Tenable plugin names into actions. All the Oracle Java findings become one action, “Update Oracle Java SE”, because the latest update replaces the earlier ones.
3. **Rank the solutions.** Each finding is weighted with Tenable's scoring, whichever product the data comes from: by severity (Critical 40, High 10, Medium 3, Low 1, the scale behind the Security Center vulnerability score), by VPR, or by VPR and ACR. The solutions that remove the most risk come first.
4. **Produce the report.** Pick a template; the file is saved in the `rapports/` folder and can optionally be sent by email.

Privacy. The application only listens on 127.0.0.1 (your own machine). Client data leaves your computer in two cases only, both initiated by you: a query to Security Center or Vulnerability Management (the data then comes from it), and sending a report through the SMTP server you configured. There is no telemetry.

2. Installation and first launch

What you need

Python 3.9 or newer (python.org). On Windows, tick “Add Python to PATH” during installation. An Internet connection is needed once, at the first launch, to download the libraries.

System	How to launch
Windows	Double-click `lancer.bat`
macOS	Double-click `lancer.command` (first time only: right-click, then Open)
Linux	`./lancer.sh`

At the first launch the script creates a `.venv` folder and installs the libraries; this takes one or two minutes. Later launches are immediate, and the script reinstalls automatically if `requirements.txt` changes. The application then opens in your browser at http://127.0.0.1:8765 (the next free port is used if 8765 is taken). To stop it, close the terminal window.

Updating

With git, run `git pull` in the application folder. Otherwise copy the new files over the application folder (your `profils/`, `config.json`, `regles/` and `rapports/` are yours: do not overwrite them). Then quit the application completely and launch it again: it does not reload its code while running, so a report generated before the restart still follows the old behaviour.

Offline install. To install on a computer without Internet access, run `pip download -r requirements.txt -d packages` on a connected machine with the same system and Python version, copy the `packages` folder across, then run `python -m venv .venv` and `.venv/bin/python -m pip install --no-index --find-links packages -r requirements.txt` (Windows: `.venv\Scripts\python.exe`).

3. Quick start

Your first report in five minutes.

1. Launch the application and, at the top right, open **Manage** to create a client profile (or keep the default one).
2. Choose the language with the flag next to **Manage**. It applies to the interface and to the reports, and is saved in the profile.
3. On the **Branding** tab, set the title, client name, colour and logo. The cover on the left updates as you type.
4. On the **Generate** tab, drop your CSV export, or fetch it through the API. A summary appears: machines, vulnerabilities, severity split and the main solutions.
5. Choose a template (use **View an example** first if you want to see what it looks like) and click **Generate the report**. PDF reports open in a new tab.

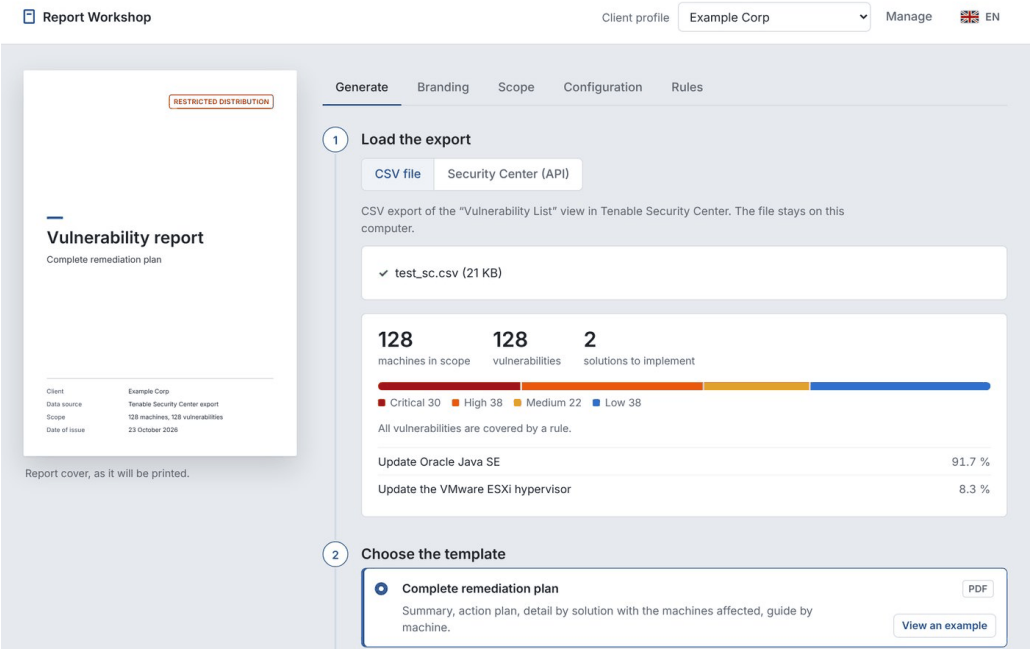


Figure 1. The Generate tab once an export is loaded: live cover preview on the left, export summary on the right.

4. Tour of the interface

Profiles and language

A profile holds everything that is specific to a client: branding, scope, Tenable product and export query, email message and language. Use **Manage** to create, duplicate, rename or delete profiles. The last profile cannot be deleted.

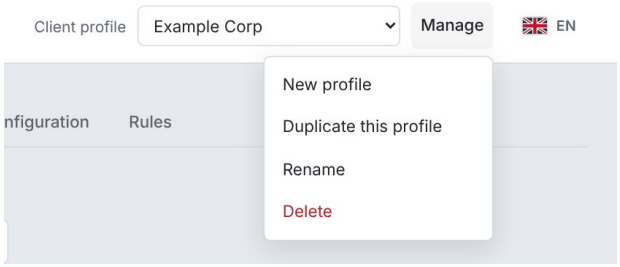


Figure 2. The profile menu.

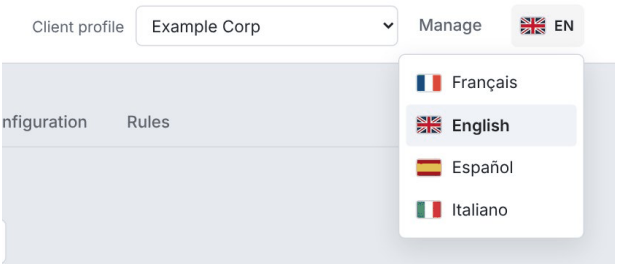


Figure 3. The language menu.

Theme

The **Theme** button, at the top right, switches the look of the application and of the reports it produces. **Atelier** is the default: the client's main colour and logo drive the reports. **Tenable** applies the Tenable brand guidelines: Aeonik typeface (Light for large titles, Regular for text, Medium for headings), Soft Black and neutral greys, sharp corners, no shadows, no gradients. The setting belongs to the application, not to a profile, and applies to the PDF reports and to the Excel action plan.

With the Tenable theme, the client's main colour is replaced by the brand palette. The profile logo is kept; without a logo, the Tenable logo is used. The cover is white by default; a dark (Soft Black) cover can be chosen in the Branding tab. Severity colours in charts and badges are data colours and are kept. The command-line option `--theme atelier|tenable` overrides the setting for one report. Aeonik is a commercial typeface and is not shipped: drop the four `Aeonik-*.ttf` files in `polices/`, otherwise the theme uses Inter.

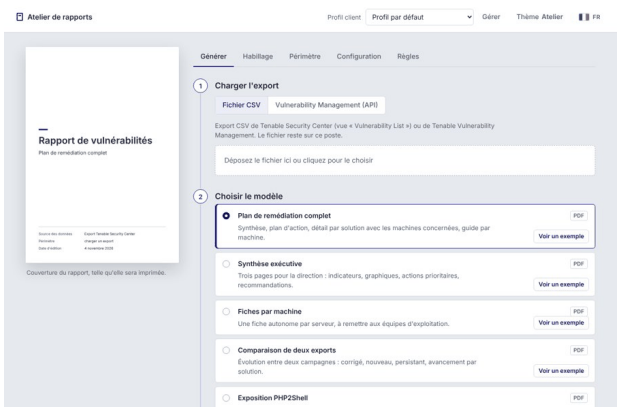


Figure 4. The Atelier theme.

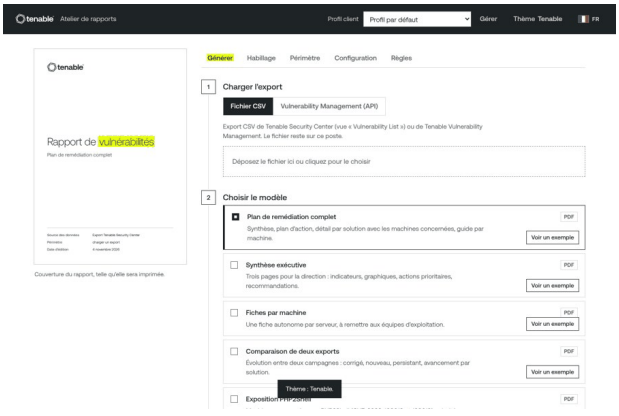


Figure 5. The Tenable theme.

Generate

The tab has three numbered steps. **1. Load the export**: from a CSV file or through the API of the profile's Tenable product. **2. Choose the template. 3. Generate the report**, with an optional email send. Below, the list of generated reports lets you open, download or send each file.

During an API retrieval, a **Retrieval log** box opens under the fetch button and fills in live: export created, status checks, chunks or pages received, asset export, conversion. If the retrieval fails, the last line gives the cause. The box can be folded.

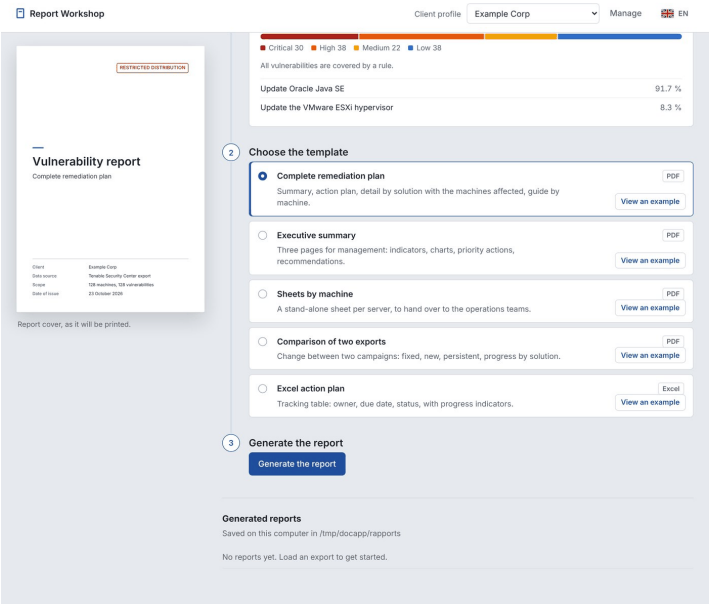


Figure 6. Template choice and the Generate button. “View an example” opens the template page by page.

Branding

Title, subtitle, client, distribution mention (a small badge on the cover, which can also appear in the header of inner pages), watermark (diagonal text on PDF pages, for example “Restricted distribution”, with a box to keep it off the cover), footer text, main colour and logo. Once a watermark or an inner-page mention is set, tabs under the preview show two fictitious inner pages.

As long as the footer text is the default one, it names the product the data comes from (“Data from Tenable Security Center” or “Data from Tenable Vulnerability Management”). The scope of an API retrieval is added to it on every page, for example “Scope: Tags: Asset Owner = ludo”. A customised footer text is kept as is.

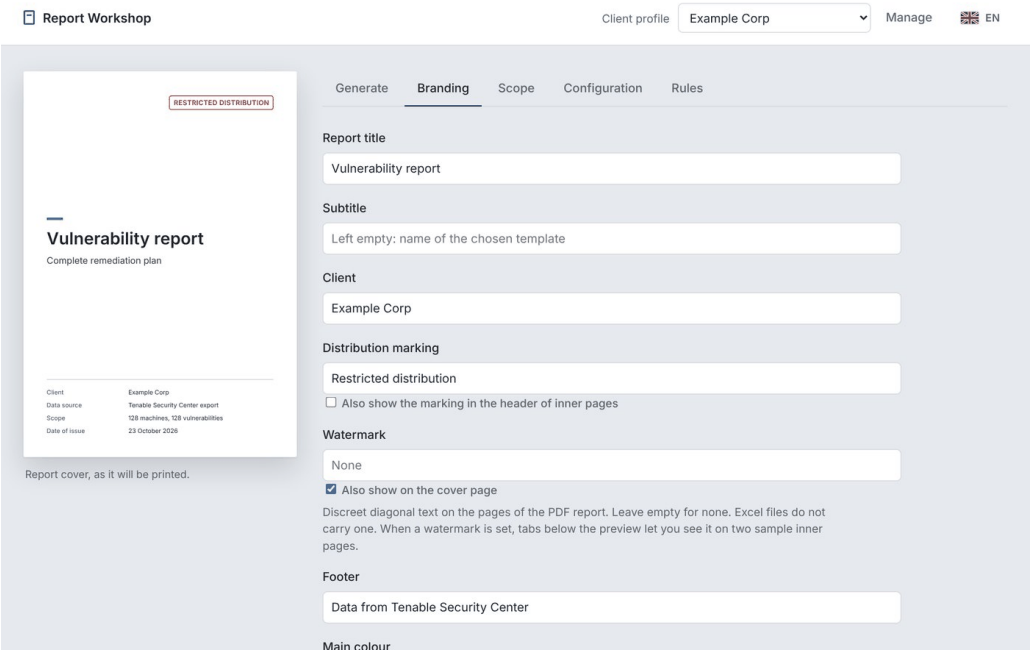


Figure 7. The Branding tab.

Scope

Choose which severities are kept, how many solutions the action plan lists, and which machines to include or exclude (an IP address, a CIDR network, or a name with wildcards). The number of solutions is a hard limit: the complete remediation plan presents only those solutions, with no list of lower-priority actions.

The risk weighting sets how the “% of risk” of each solution is computed (it is calculated by the tool, never read from the API). A solution's “% of risk” is the weight of its findings divided by the weight of all findings in the scope, so the percentages add up to 100%. Three weightings are offered: by severity (Critical 40, High 10, Medium 3, Low 1, Tenable's severity scale); by VPR (each finding weighs its VPR, 0.1 to 10, or the median of its severity, 9.5 / 8.0 / 5.5 / 2.0, when it has none); by VPR and ACR (VPR × ACR ÷ 10, adding the importance of the machine; Tenable's default ACR of 5 is used when it is missing). The weighting changes the ranking of solutions, not the per-machine score or the comparison of two exports.

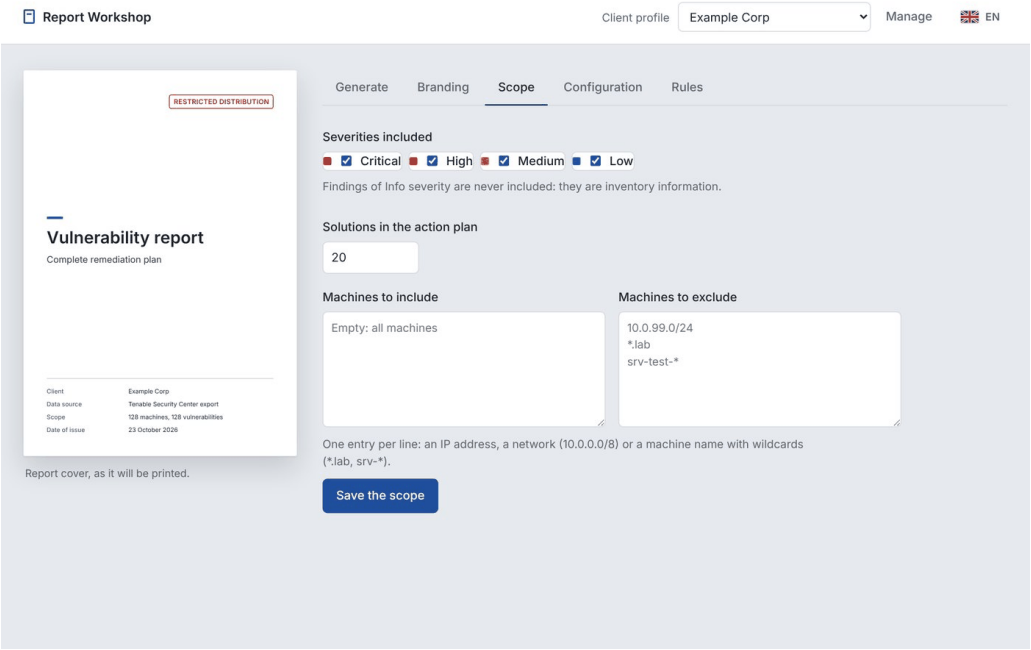


Figure 8. The Scope tab.

Configuration

Three blocks: **Tenable product** (Security Center or Vulnerability Management, a setting of the profile), the section of the chosen product (server and API keys, shared by all profiles; the export query, specific to the profile) and **Email** (SMTP server, shared; default message, specific to the profile). See chapters 5 and 9.

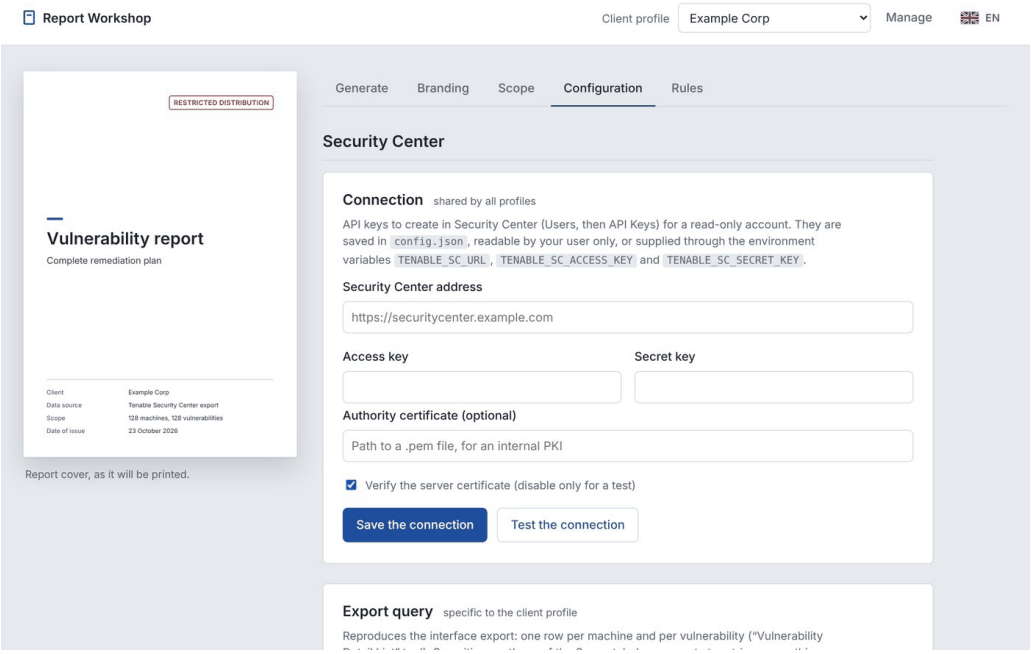


Figure 9. The Configuration tab. With Vulnerability Management, the export query also offers the detection period.

5. Getting the data

Option A: CSV export from the Security Center interface

1. Open **Analysis > Vulnerabilities**.
2. Choose the **Vulnerability List** view.
3. Apply your filters.
4. Click **Export**, then **Export as CSV**.

Required columns: Plugin, Plugin Name, Severity, IP Address. Recommended: DNS Name, NetBIOS Name, Family, VPR, CVE, and Solution for titles that have no rule. Optional: ACR and AES, which add the asset scores to the reports. A CSV re-saved by a French Excel (semicolon separator, decimal comma) is accepted too.

Option B: query Security Center directly (API)

1. **Configuration > Security Center > Connection.** Enter the server address and the API keys (in Security Center: Users, then API Keys; a read-only account is best). "Test the connection" checks the keys. For an internal PKI, give the authority certificate (PEM file); only disable TLS verification for a test.
2. **Export query** (per profile): repositories, asset list or saved query, and optional extra filters in JSON. The button that lists the available repositories, asset lists and queries lets you pick them with a click. Severities come from the Scope tab. "View the request sent to the API" shows the exact JSON body of the `POST /rest/analysis` call.
3. **Generate > step 1:** choose "Security Center (API)", then "Fetch from Security Center". The retrieval log shows the pages as they arrive.

Option C: Tenable Vulnerability Management

A CSV exported from Vulnerability Management (columns asset.* and definition.*) is dropped like any other CSV: the format is detected automatically. It carries no ACR, AES or last-observed date, so the AES and CES blocks are left out. A machine is identified by its first IPv4 address, because Vulnerability Management can hold the same host under several asset identifiers.

To fetch the data through the API, choose **Configuration > Tenable product > Tenable Vulnerability Management** (a setting of the profile), then fill in the **Vulnerability Management** section: address (https://cloud.tenable.com by default) and API keys (Settings, My Profile, API Keys). The export query of the profile sets:

- **Detection period**: 30 days (Tenable's default), 90, 180, 365 days or the whole period. Without a date, the export API only returns vulnerabilities seen in the last 30 days, so a machine that has not been rescanned since disappears from the report. Widen the period to bring it back.
- **Address range** (optional).
- **ACR and AES**: read from the asset export (`POST /assets/v2/export`). If that export is refused, the application reads the scores from the workbench asset list, then tries the asset export v1.

Generate > step 1 then offers "Vulnerability Management (API)". From the command line, `--api` uses the profile's product. The environment variables are `TENABLE_VM_URL`, `TENABLE_VM_ACCESS_KEY` and `TENABLE_VM_SECRET_KEY`. The client has been run against a live tenant (vulnerability export, tags, detection period, asset export); if a field is not recognised, the error lists the fields received.

Choosing the scope

Step 1 of the Generate tab offers **Choose the scope**: asset lists with Security Center (several lists are combined, OR), tags by category with Vulnerability Management (OR within a category, AND between categories), with a machine count before the export. Use it for one report, or save it in the profile.

With Vulnerability Management, if the export's tag filter returns nothing or is rejected, the application looks up the assets that carry those tags in the workbench and keeps only their vulnerabilities; the log says which path was used. If none of the tagged machines has a vulnerability in the period, the message suggests widening the detection period.

The selection appears on the **cover**, in the **footer of every page** and in the Excel plan, and the application warns when two compared exports differ in scope. It is also written into the fetched CSV (a `Scope` column), so a report built later from that file still shows it.

Where the fetched data is kept

Each retrieval is kept as a timestamped CSV, in `exports_security_center/` or `exports_vulnerability_management/`. These files are the natural input for comparisons: load last month's file as the previous export, and fetch the recent one from the API.

API keys are stored in `config.json`, readable by your user only. You can supply them through the environment variables `TENABLE_SC_URL`, `TENABLE_SC_ACCESS_KEY`, `TENABLE_SC_SECRET_KEY` (and their `TENABLE_VM_*` counterparts) instead, which take precedence. Never share `config.json`.

6. The report templates

Six templates are available. “View an example” next to each one produces the real report from fictitious data, with the branding and language of the active profile, and shows it page by page.

Template	Format	What it contains
Complete remediation plan	PDF	How-to-read guide, graphical summary, action plan, detail by solution with the machines affected, remediation guide by machine. Only the solutions of the action plan are presented.
Executive summary	PDF	For management: how-to-read guide, indicators, charts, exposure posture, the priority actions, recommendations.
Sheets by machine	PDF	Guide, index, then one stand-alone sheet per machine: tick-box actions, vulnerabilities fixed, an intervention tracking box. To hand to the operations teams.
Comparison of two exports	PDF	Change in the risk score, vulnerabilities fixed, new and persistent, progress by solution and by machine. Load the previous export first, then the recent one.
PHP2Shell exposure	PDF	Dedicated report on the PHP flaws CVE-2026-109618 and CVE-2026-109619: threat summary, every machine concerned ranked by priority, action plan, interim measures, compromise checklist, detection reliability, plugin coverage and sources.
Excel action plan	XLSX	Tracking workbook: owner, due date and status per solution, status per machine, vulnerability detail, progress indicators that recalculate.

In every PDF the page that follows the cover is “How to read this report”: method, definitions of VPR, ACR, AES and CES, and a reading gauge. In the executive summary this page is shorter and written for management.

In a comparison, a vulnerability counts as fixed only if its machine was rescanned, that is, it appears in the recent export with any finding, Info included. A machine whose last vulnerability was fixed therefore gets the credit.

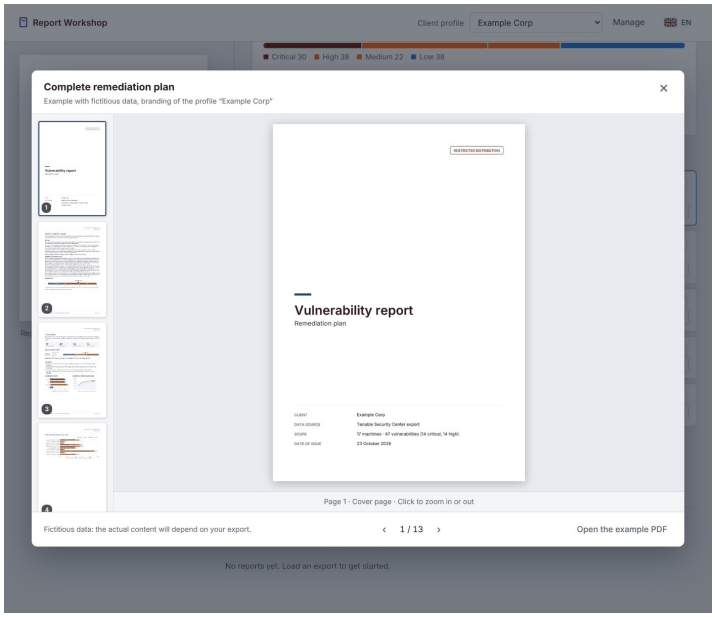
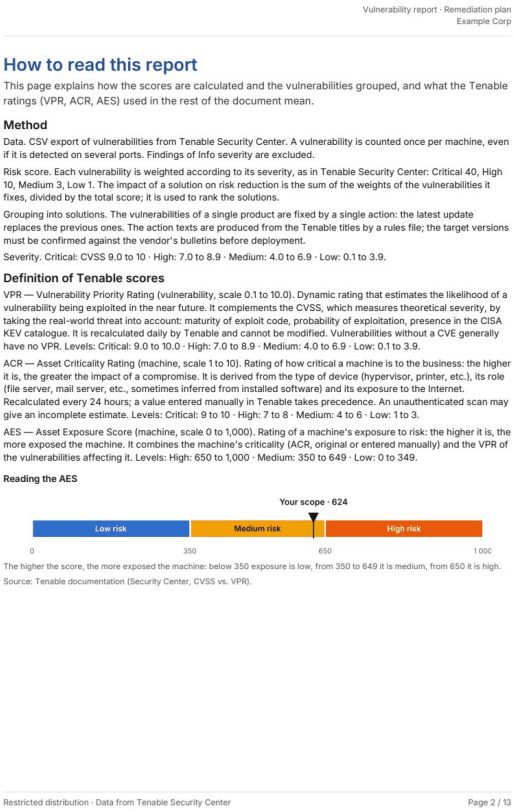


Figure 10. “View an example”: thumbnails on the left, click the page to zoom, arrow keys to navigate.

What the pages look like



Vulnerability report · Remediation plan
Example Corp

How to read this report

This page explains how the scores are calculated and the vulnerabilities grouped, and what the Tenable ratings (VPR, ACR, AES) used in the rest of the document mean.

Method

Data. CSV export of vulnerabilities from Tenable Security Center. A vulnerability is counted once per machine, even if it is detected on several ports. Findings of Info severity are excluded.

Risk score. Each vulnerability is weighted according to its severity, as in Tenable Security Center: Critical 40, High 10, Medium 3, Low 1. The impact of a solution on risk reduction is the sum of the weights of the vulnerabilities it fixes, divided by the total score; it is used to rank the solutions.

Grouping into solutions. The vulnerabilities of a single product are fixed by a single action: the latest update replaces the previous ones. The action texts are produced from the Tenable titles by a rules file; the target versions must be confirmed against the vendor's bulletins before deployment.

Severity. Critical: CVSS 9.0 to 10 · High: 7.0 to 8.9 · Medium: 4.0 to 6.9 · Low: 0.1 to 3.9.

Definition of Tenable scores

VPR — Vulnerability Priority Rating (vulnerability, scale 0.1 to 10.0). Dynamic rating that estimates the likelihood of a vulnerability being exploited in the near future. It complements the CVSS, which measures theoretical severity, by taking the real-world threat into account: maturity of exploit code, probability of exploitation, presence in the CISA KEV catalogue. It is recalculated daily by Tenable and cannot be modified. Vulnerabilities without a CVE generally have no VPR. Levels: Critical: 9.0 to 10.0 · High: 7.0 to 8.9 · Medium: 4.0 to 6.9 · Low: 0.1 to 3.9.

ACR — Asset Criticality Rating (machine, scale 1 to 10). Rating of how critical a machine is to the business: the higher it is, the greater the impact of a compromise. It is derived from the type of device (hypervisor, printer, etc.), its role (file server, mail server, etc., sometimes inferred from installed software) and its exposure to the Internet. Recalculated every 24 hours; a value entered manually in Tenable takes precedence. An unauthenticated scan may give an incomplete estimate. Levels: Critical: 9 to 10 · High: 7 to 8 · Medium: 4 to 6 · Low: 1 to 3.

AES — Asset Exposure Score (machine, scale 0 to 1,000). Rating of a machine's exposure to risk: the higher it is, the more exposed the machine. It combines the machine's criticality (ACR, original or entered manually) and the VPR of the vulnerabilities affecting it. Levels: High: 650 to 1,000 · Medium: 350 to 649 · Low: 0 to 349.

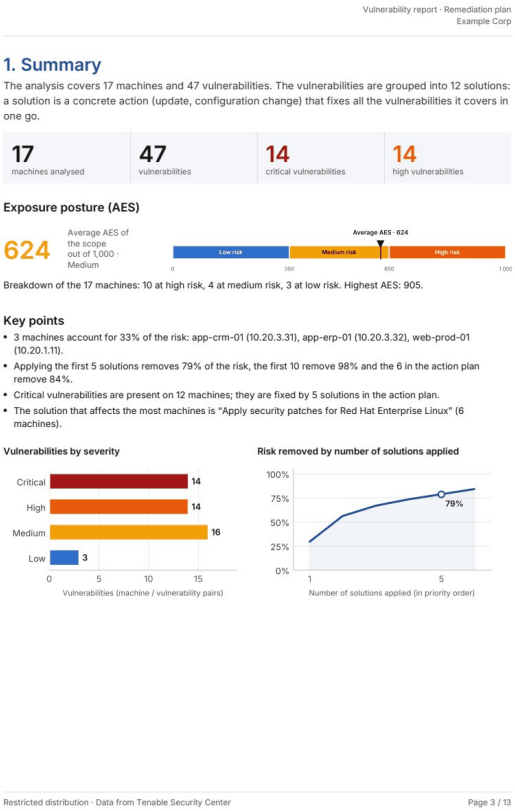
Reading the AES

The higher the score, the more exposed the machine: below 350 exposure is low, from 350 to 649 it is medium, from 650 it is high.

Source: Tenable documentation (Security Center, CVSS vs. VPR).

Restricted distribution · Data from Tenable Security Center
Page 2 / 13

Figure 11. “How to read this report”, always page 2.



Vulnerability report · Remediation plan
Example Corp

1. Summary

The analysis covers 17 machines and 47 vulnerabilities. The vulnerabilities are grouped into 12 solutions: a solution is a concrete action (update, configuration change) that fixes all the vulnerabilities it covers in one go.

17	47	14	14
machines analysed	vulnerabilities	critical vulnerabilities	high vulnerabilities

Exposure posture (AES)

624 — Average AES of the scope out of 1,000 · Medium

Breakdown of the 17 machines: 10 at high risk, 4 at medium risk, 3 at low risk. Highest AES: 905.

Key points

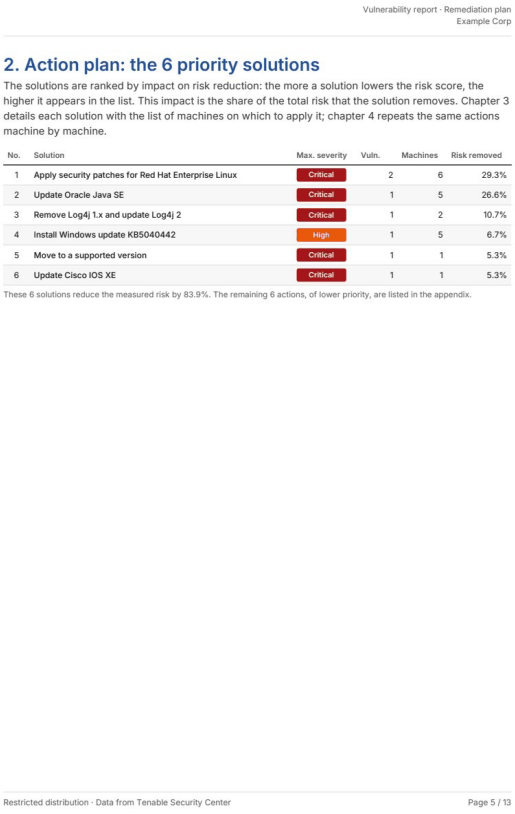
- 3 machines account for 33% of the risk: app-crm-01 (10.20.3.31), app-erp-01 (10.20.3.32), web-prod-01 (10.20.1.11).
- Applying the first 5 solutions removes 79% of the risk, the first 10 remove 98% and the 6 in the action plan remove 84%.
- Critical vulnerabilities are present on 12 machines; they are fixed by 5 solutions in the action plan.
- The solution that affects the most machines is “Apply security patches for Red Hat Enterprise Linux” (6 machines).

Vulnerabilities by severity

Risk removed by number of solutions applied

Restricted distribution · Data from Tenable Security Center
Page 3 / 13

Figure 12. Summary with the Cyber Exposure Score posture.



Vulnerability report · Remediation plan
Example Corp

2. Action plan: the 6 priority solutions

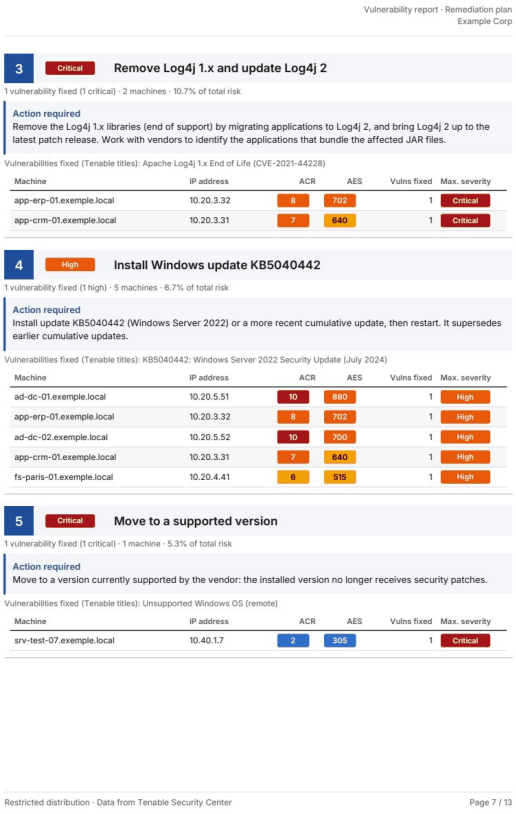
The solutions are ranked by impact on risk reduction: the more a solution lowers the risk score, the higher it appears in the list. This impact is the share of the total risk that the solution removes. Chapter 3 details each solution with the list of machines on which to apply it; chapter 4 repeats the same actions machine by machine.

No.	Solution	Max. severity	Vuln.	Machines	Risk removed
1	Apply security patches for Red Hat Enterprise Linux	Critical	2	6	29.3%
2	Update Oracle Java SE	Critical	1	5	26.6%
3	Remove Log4j 1.x and update Log4j 2	Critical	1	2	10.7%
4	Install Windows update KB5040442	High	1	5	6.7%
5	Move to a supported version	Critical	1	1	5.3%
6	Update Cisco IOS XE	Critical	1	1	5.3%

These 6 solutions reduce the measured risk by 83.9%. The remaining 6 actions, of lower priority, are listed in the appendix.

Restricted distribution · Data from Tenable Security Center
Page 5 / 13

Figure 13. Action plan, ranked by risk removed.



Vulnerability report · Remediation plan
Example Corp

3 Critical — Remove Log4j 1.x and update Log4j 2

1 vulnerability fixed (1 critical) · 2 machines · 10.7% of total risk

Action required
Remove the Log4j 1.x libraries (end of support) by migrating applications to Log4j 2, and bring Log4j 2 up to the latest patch release. Work with vendors to identify the applications that bundle the affected JAR files.

Vulnerabilities fixed (Tenable titles): Apache Log4j 1.x End of Life (CVE-2021-44228)

Machine	IP address	ACR	AES	Vulns fixed	Max. severity
app-erp-01.exemple.local	10.20.3.32	8	702	1	Critical
app-crm-01.exemple.local	10.20.3.31	7	640	1	Critical

4 High — Install Windows update KB5040442

1 vulnerability fixed (1 high) · 5 machines · 6.7% of total risk

Action required
Install update KB5040442 (Windows Server 2022) or a more recent cumulative update, then restart. It supersedes earlier cumulative updates.

Vulnerabilities fixed (Tenable titles): KB5040442: Windows Server 2022 Security Update (July 2024)

Machine	IP address	ACR	AES	Vulns fixed	Max. severity
ad-dc-01.exemple.local	10.20.5.51	10	880	1	High
app-erp-01.exemple.local	10.20.3.32	8	702	1	High
ad-dc-02.exemple.local	10.20.5.52	10	700	1	High
app-crm-01.exemple.local	10.20.3.31	7	640	1	High
fs-paris-01.exemple.local	10.20.4.41	6	515	1	High

5 Critical — Move to a supported version

1 vulnerability fixed (1 critical) · 1 machine · 5.3% of total risk

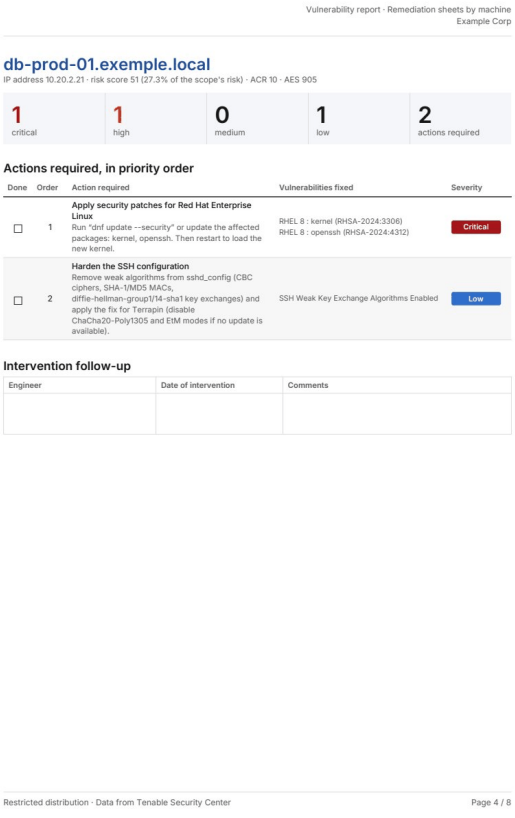
Action required
Move to a version currently supported by the vendor: the installed version no longer receives security patches.

Vulnerabilities fixed (Tenable titles): Unsupported Windows OS (remote)

Machine	IP address	ACR	AES	Vulns fixed	Max. severity
srv-test-07.exemple.local	10.40.1.7	2	305	1	Critical

Restricted distribution · Data from Tenable Security Center
Page 7 / 13

Figure 14. Detail by solution, with the machines to treat.



Vulnerability report · Remediation sheets by machine
Example Corp

db-prod-01.exemple.local

IP address 10.20.2.21 · risk score 51 (27.3% of the scope's risk) · ACR 10 · AES 905

1	1	0	1	2
critical	high	medium	low	actions required

Actions required, in priority order

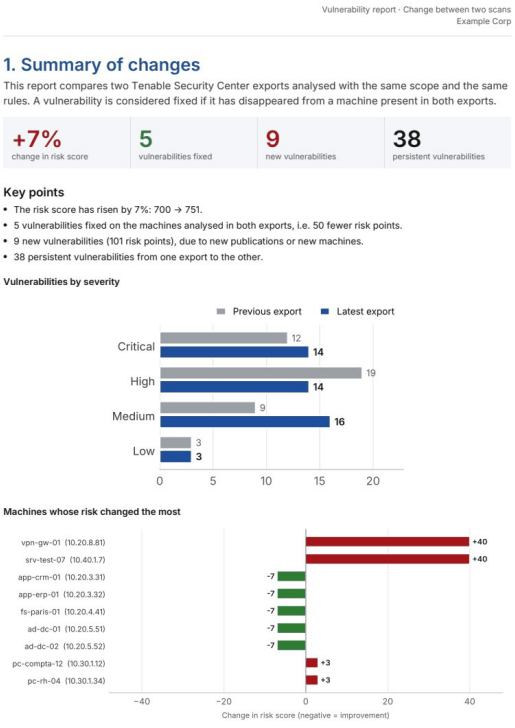
Done	Order	Action required	Vulnerabilities fixed	Severity
☐	1	**Apply security patches for Red Hat Enterprise Linux** Run "dnf update --security" or update the affected packages: kernel, openssh. Then restart to load the new kernel.	RHEL 8 : kernel (RHSA-2024:3306) RHEL 8 : openssh (RHSA-2024:4312)	Critical
☐	2	**Harden the SSH configuration** Remove weak algorithms from sshd_config (CBC ciphers, SHA-1/MD5 MACs, diffie-hellman-group1/14-sha1 key exchanges) and apply the fix for Terrapin (disable ChaCha20-Poly1305 and EtM modes if no update is available).	SSH Weak Key Exchange Algorithms Enabled	Low

Intervention follow-up

Engineer	Date of intervention	Comments

Restricted distribution · Data from Tenable Security Center
Page 4 / 8

Figure 15. A sheet for one machine.



Vulnerability report · Change between two scans
Example Corp

1. Summary of changes

This report compares two Tenable Security Center exports analysed with the same scope and the same rules. A vulnerability is considered fixed if it has disappeared from a machine present in both exports.

+7%	5	9	38
change in risk score	vulnerabilities fixed	new vulnerabilities	persistent vulnerabilities

Key points

- The risk score has risen by 7%: 700 → 751.
- 5 vulnerabilities fixed on the machines analysed in both exports, i.e. 50 fewer risk points.
- 9 new vulnerabilities (101 risk points), due to new publications or new machines.
- 38 persistent vulnerabilities from one export to the other.

Vulnerabilities by severity

Machines whose risk changed the most

Restricted distribution · Data from Tenable Security Center
Page 3 / 6

Figure 16. Comparison summary.

The PHP2Shell template

PHP2Shell is the name given to two critical PHP flaws, CVE-2026-109618 and CVE-2026-109619: unauthenticated remote code execution, exploited in the wild since 21 October 2026. This template isolates, in your export, every finding that cites either CVE, plus the 43 Nessus plugins published for them.

Nothing is filtered out. Every machine concerned is listed, whatever its AES or ACR, and the profile's severity filter is ignored for this report. ACR and AES are shown and used for sorting only. The priority depends on the level of evidence alone: P1 confirmed flaw, or no vendor fix (act within 24 to 48 hours), P2 to be confirmed (version read from a remote banner by an unauthenticated scan).

The report also explains when an empty result proves nothing: export older than the plugins, unauthenticated or agent scan, PHP bundled in an application. The threat summary is dated 25 October 2026; check it before circulating a later report.



Vulnerability report · PHP2Shell exposure
Example client

How to read this report

This report isolates, within your Security Center export, the machines affected by PHP2Shell: two critical PHP flaws that allow unauthenticated remote code execution, exploited since 21 October 2026.

Scope of the analysis

Findings that cite CVE-2026-109618 or CVE-2026-109619 are retained, along with the 43 Nessus plugins published for these flaws (PHP version check, distribution advisories, vendor fix not published). The other vulnerabilities in the export are not covered here: use the full remediation plan to see them. The profile's severity filter is ignored for this report, so that no PHP2Shell finding is missing.

Levels of evidence

Level of evidence	What this means
Confirmed	A distribution advisory, a local version check or a direct test establishes that PHP is vulnerable: it is not an assumption.
No vendor fix	The distribution has not yet published a fix: only interim measures are possible.
To confirm	Version inferred from the service banner, without authentication: to be checked, since a distribution often fixes without changing the version number.

Priorities

Priority	Criterion	Recommended deadline
P1	Confirmed flaw, or no vendor fix: unauthenticated remote code execution, already exploited.	24 to 48 hours
P2	Finding to confirm: version inferred from the remote banner of an unauthenticated scan.	After checking

All affected machines are listed, with no filter on AES or ACR. The priority rests on the level of evidence; it does not replace your knowledge of real exposure (machine published on the Internet, isolated segment, load balancer).

Definition of Tenable scores

VPR — Vulnerability Priority Rating (vulnerability, scale 0.1 to 10.0). Dynamic rating that estimates the likelihood of a vulnerability being exploited in the near future. It complements the CVSS, which measures theoretical severity, by taking the real-world threat into account: maturity of exploit code, probability of exploitation, presence in the CISA KEV catalogue. It is recalculated daily by Tenable and cannot be modified. Vulnerabilities without a CVE generally have no VPR. Levels: Critical: 9.0 to 10.0 · High: 7.0 to 8.9 · Medium: 4.0 to 6.9 · Low: 0.1 to 3.9.

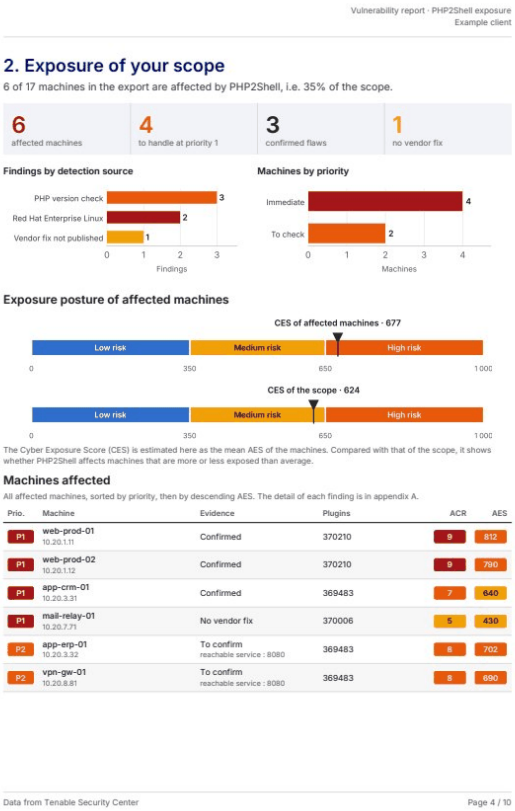
ACR — Asset Criticality Rating (machine, scale 1 to 10). Rating of how critical a machine is to the business: the higher it is, the greater the impact of a compromise. It is derived from the type of device (hypervisor, printer, etc.), its role (file server, mail server, etc., sometimes inferred from installed software) and its exposure to the Internet. Recalculated every 24 hours; a value entered manually in Tenable takes precedence. An unauthenticated scan may give an incomplete estimate. Levels: Critical: 9 to 10 · High: 7 to 8 · Medium: 4 to 6 · Low: 1 to 3.

AES — Asset Exposure Score (machine, scale 0 to 1,000). Rating of a machine's exposure to risk: the higher it is, the more exposed the machine. It combines the machine's criticality (ACR, original or entered manually) and the VPR of the vulnerabilities affecting it. Levels: High: 650 to 1,000 · Medium: 350 to 649 · Low: 0 to 349.

CES — Cyber Exposure Score (set of machines, scale 0 to 1,000). Overall exposure score for a set of machines (the organisation or a scope). Tenable derives it from the AES of the machines, on the same 0 to 1,000 scale and with the same levels. In this report the scope's CES is estimated as the mean AES of the machines analysed (one machine, one vote). Levels: High: 650 to 1,000 · Medium: 350 to 649 · Low: 0 to 349.

Data from Tenable Security Center
Page 2 / 10

Figure 17. PHP2Shell: how to read this report.



Vulnerability report · PHP2Shell exposure
Example client

2. Exposure of your scope

6 of 17 machines in the export are affected by PHP2Shell, i.e. 35% of the scope.

6	4	3	1
affected machines	to handle at priority 1	confirmed flaws	no vendor fix

Findings by detection source

PHP version check 3
Red Hat Enterprise Linux 2
Vendor fix not published 1
0 1 2 3
Findings

Machines by priority

Immediate 4
To check 2
0 1 2 3 4
Machines

Exposure posture of affected machines

CES of affected machines · 677
Low risk | Medium risk | High risk
0 350 650 1 000

CES of the scope · 624
Low risk | Medium risk | High risk
0 350 650 1 000

The Cyber Exposure Score (CES) is estimated here as the mean AES of the machines. Compared with that of the scope, it shows whether PHP2Shell affects machines that are more or less exposed than average.

Machines affected

All affected machines, sorted by priority, then by descending AES. The detail of each finding is in appendix A.

Prio.	Machine	Evidence	Plugins	ACR	AES
P1	web-prod-01 10.20.1.11	Confirmed	370210	9	812
P1	web-prod-02 10.20.1.12	Confirmed	370210	9	780
P1	app-crm-01 10.20.3.31	Confirmed	369483	7	640
P1	mail-relay-01 10.20.7.71	No vendor fix	370006	5	430
P2	app-erp-01 10.20.3.32	To confirm reachable service : 8080	369483	8	702
P2	vpn-gw-01 10.20.8.81	To confirm reachable service : 8080	369483	8	690

Data from Tenable Security Center
Page 4 / 10

Figure 18. Machines concerned, all listed.

7. Understanding the scores

The reports use five scores. They are Tenable's own scores and apply in the same way to Security Center and Vulnerability Management data. Knowing which is which makes the rankings easy to explain.

Score	Applies to	Scale	What it tells you
Risk score	Report	40 / 10 / 3 / 1	Each vulnerability counts by severity, with Tenable's severity scale (the one behind the Security Center vulnerability score), for both products. The impact of a solution is the share of the total score it removes. This ranks the solutions.
VPR	Vulnerability	0.1 to 10.0	Vulnerability Priority Rating: how likely the flaw is to be exploited soon (exploit maturity, threat intelligence).
ACR	Machine	1 to 10	Asset Criticality Rating: how important the machine is to the business.
AES	Machine	0 to 1,000	Asset Exposure Score: how exposed the machine is; it combines the ACR and the VPR of its vulnerabilities. Low below 350, Medium 350 to 649, High 650 and above.
CES	Scope	0 to 1,000	Cyber Exposure Score: Tenable's overall exposure score for a set of machines. The reports estimate it as the mean AES of the machines analysed (one machine, one vote).

Where the scores appear

Machines are sorted by AES, most exposed first, and ACR and AES are shown as colour-coded badges. The summary pages show an exposure posture block: the Cyber Exposure Score of the scope, a gauge from low risk to high risk with a marker for your value, and the number of machines in each level.

ACR and AES come from the CSV columns of the same name, from the Security Center API (`acrScore`, `assetExposureScore`) or from the Vulnerability Management asset export. If they are missing, these elements are simply left out; nothing else changes.

8. Rules

Rules are what turn a Tenable title such as “Oracle Java SE 8 Update 421 Multiple Vulnerabilities” into an action. The first rule whose pattern matches the plugin name (and, if given, the Tenable family) is used. Findings that share a grouping key form one solution.

The rule set covers Linux and Unix, Windows, the main network and security vendors (Cisco, Fortinet, Palo Alto, Juniper, F5, Check Point, Citrix, SAP, IBM), industrial systems and protocols (Modbus, DNP3, BACnet), and common issues such as TLS, certificates, SSH, SMB, SNMP, DNS, WPAD, credentials sent in cleartext, Secure Boot, RADIUS authentication failures and suspicious processes. Generic rules handle titles such as “Product < X” or “Product X (GHSA-… / CVE-…)”.

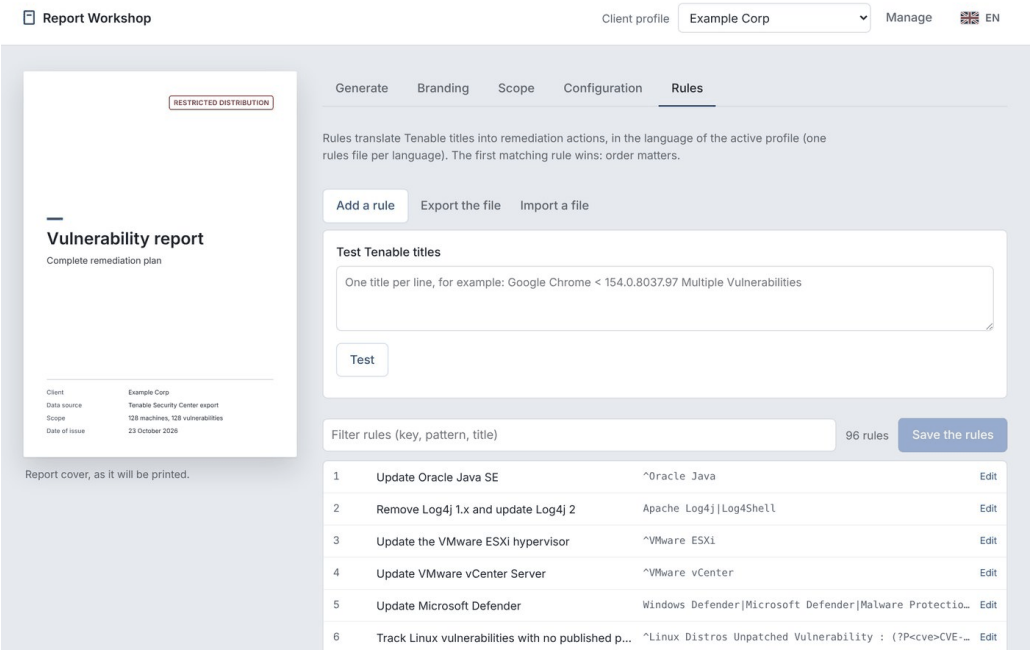


Figure 19. The Rules tab: test area on top, then the ordered list of rules.

What you can do

- Test one or several titles, including with edits you have not saved yet.
- Pick up unmatched titles from the loaded export in one click, and create a pre-filled rule from one of them.
- Edit, reorder or delete rules. Order matters: the first match wins.
- Import or export the file to work on it in Excel (semicolon separator).

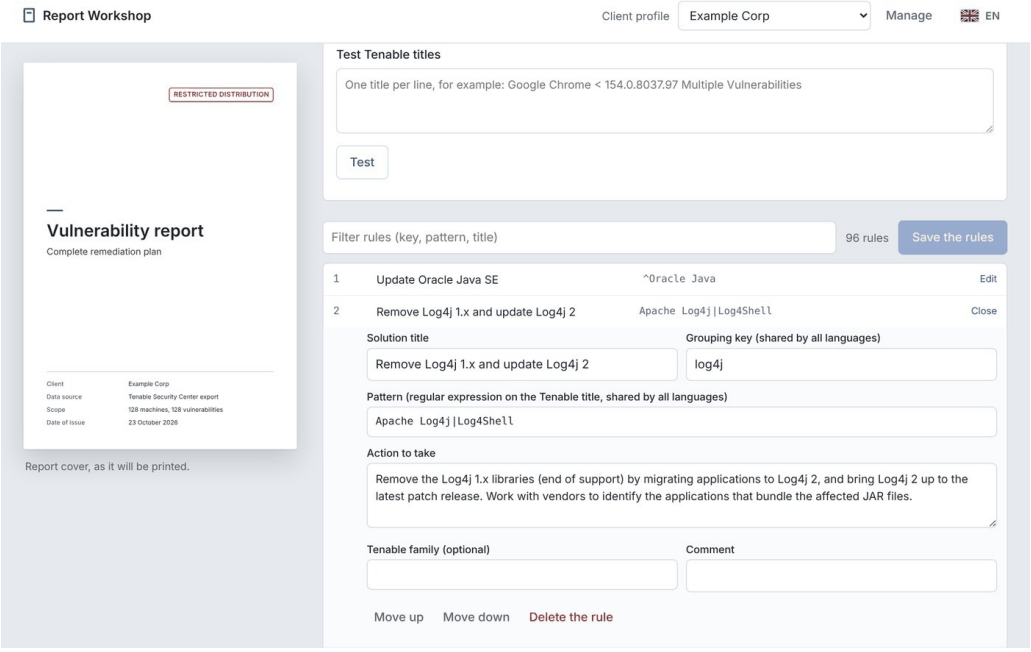


Figure 20. Editing a rule: title, grouping key, pattern, action, optional family and comment.

Fields you can use in a title or an action

Field	Content
`{produit}` `{kb}` `{os}` `{ms}` `{famille}`	Values extracted from the title by the named groups of the pattern
`{paquets}` `{avis}` `{notes}` `{bulletins}` `{cves}`	Lists accumulated over all the vulnerabilities of the solution
`{cible}`	“to version X or later”, from titles like “Product < X” or “Product X (GHSA-…)”
`{precision}`	“(version X or later)” when a version is cited, otherwise empty
`{branches}`	Fixed versions of the other branches, when the title names several
`{ref_avis}`	“(advisory: …)” when the title cites vendor advisory identifiers, GHSA included
`{mois}`	Latest publication month
`{redemarrage}`	A restart sentence when the kernel is concerned

How the rules are stored

The grouping (pattern, key, family) is shared by all languages, in `regles/base.csv`. The texts (title, action, comment) are one file per language, `regles/textes_<language>.csv`. English is the reference language: a text missing in another language is taken from English, then from French. Each save writes the files completely before replacing the old ones, which are kept with a `.bak` extension.

Target versions are deduced from Tenable titles, so have the technical team review the action plan before it is circulated.

9. Sending a report by email

Sending is always optional and explicit: nothing is ever sent without your choosing it.

1. **Configuration > Email > SMTP server** (shared by all profiles): server, port, encryption (STARTTLS, SSL/TLS, or none for an internal relay), credentials if any, and the sender address. “Test the connection” opens a session and authenticates without sending a message. The password can come from the `SMTP_PASSWORD` variable.
2. **Default message** (per profile): usual recipients, subject and text. Variables: `{titre}`, `{client}`, `{date}`, `{fichier}`.
3. On **Generate > step 3**, “Generate the report” only creates the file. “Generate and send by email” (shown once the SMTP server is configured) also sends it to the profile's recipients.

If the send fails, the report is kept and a “Try again” link opens the send form; the “Send” link in the list of reports does the same, with editable recipients. The report goes as an attachment, 25 MB at most.

10. Command line and automation

Everything the interface does can be run without it, which suits a scheduled task (cron, Windows Task Scheduler). Use the Python of the `.venv` folder.

```
python generer.py export.csv --modele synthese --profil client-name
python generer.py old.csv recent.csv --modele comparaison --sortie change.pdf
python generer.py --api --profil client-name --mail defaut
python generer.py old.csv --api --modele comparaison --profil client-name
python generer.py export.csv --langue en
```

Option	Meaning
`--modele`	complet, synthese, fiches, comparaison, php2shell or plan_excel
`--profil`	Profile name: the file name in `profils/` without `.json`
`--sortie`	Output file (default: rapport_<template>.pdf or .xlsx in the current folder)
`--langue`	fr, en, es or it. By default, the profile's language
`--theme`	atelier or tenable. By default, the application's setting
`--api` / `--securitycenter`	Fetch the export through the API of the profile's product, with its query and scope (for a comparison, it replaces the recent export)
`--mail`	Send the report to the given addresses (comma separated), or to the profile's recipients with “defaut”

11. Languages

The flag selector next to profile management switches the interface and the reports between French, English, Spanish and Italian. The language is saved in the profile, so each client can have their own. Default texts (title, footer, email message) follow the language as long as you have not customised them; customised texts are never overwritten. Rules are translated too (chapter 8). For the command line, `--langue` overrides the profile.

12. What is in the folder

Item	Role
`app.py`	Local server and interface
`generer.py`	Command-line generation
`moteur/`	Analysis, rules, charts, report templates (`moteur/modeles/`), Security Center and Vulnerability Management clients, scope, SMTP sending, configuration, translations
`web/`	The interface (HTML, CSS, JavaScript; no external resource)
`regles/`	Rules: `base.csv` (grouping) and one text file per language
`profils/`	Client profiles: branding, scope, logo
`config.json`	Security Center and Vulnerability Management connections, SMTP server (created on save, restricted permissions)
`exports_security_center/`	Security Center exports fetched through the API, kept for comparisons
`exports_vulnerability_management/`	Vulnerability Management exports fetched through the API, kept for comparisons
`rapports/`	Generated reports
`polices/`	Inter and DejaVu fonts, free licences included
`outils/guide/`	The script and screenshots that produce this guide

Adding a report template

1. Create a file in `moteur/modeles/` with a `generer(analyse, habillage, sortie)` function (for a two-export template: `generer(avant, apres, habillage, sortie)`).
2. Declare it in `moteur/modeles/__init__.py`.

Shared layout blocks (cover, tables, severity badges, indicators) are in `moteur/commun.py`. To update this guide, edit `outils/guide/generer_guide.py` and run it with the Python of the `.venv` folder.

13. Troubleshooting

You see	What to do
The application opens with the old layout, or a report ignores a recent change	Quit the application completely (close the terminal window), launch it again and generate a new report. Reports already generated are not rebuilt.
macOS refuses to open `lancer.command`	Right-click the file, choose Open, confirm. This is needed once. If the message is about permissions, run `chmod +x lancer.command` in the application folder.
An API retrieval seems slow	Open the Retrieval log under the fetch button: it shows whether Tenable is still preparing the export (QUEUED, PROCESSING) or whether chunks are arriving.
Machines carrying a Vulnerability Management tag are missing	They were probably not rescanned in the last 30 days. Widen the Detection period of the profile's export query (90, 180, 365 days or the whole period).
ACR and AES are missing	CSV: the export has no such columns. Security Center API: the fields used are `acrScore` and `assetExposureScore`. Vulnerability Management API: check the Retrieval log; the scores need a Tenable One or Lumin licence.
The scope is not shown on the report	The scope comes with an API retrieval. A CSV fetched with an older version has no `Scope` column: fetch it again.
“The Plugin Name column is empty”	The file is empty or is not a Vulnerability List export. If it comes from the API, fetch it again with the latest version.
“No vulnerabilities in the selected scope”	Check the severities on the Scope tab and the include/exclude filters. Info findings are always excluded.
“N names without a dedicated rule”	The report is produced, but those titles fall into generic rules. Open the Rules tab, pick up the unmatched titles and create rules.
Cannot reach Security Center or Vulnerability Management	Use “Test the connection” in Configuration. Check the address, the keys and, for an internal PKI, the PEM certificate.
The email does not leave	Use “Test the connection” on the SMTP card. The report is kept; use “Try again”. Attachments are limited to 25 MB.
A rule edit went wrong	Previous files are kept next to the originals in `regles/` with a `.bak` extension; rename one to restore it.
The image preview asks for the “pypdfium2” library	Run `.venv/bin/python -m pip install -r requirements.txt` (Windows: `.venv\Scripts\python.exe`) and relaunch. The launchers do this automatically.

Before you share. Check the action plan with the technical team before circulating a report: target versions are deduced from Tenable titles and should be confirmed against the vendors' bulletins.